Standard: SECURITY-POL00004-STN00009
Driver: Todd Powers
Classification: Internal
Version 10.0

Logical Access Account Standard

1. Overview

The purpose of this Logical Access Account Standard is to define the minimum requirements and methodologies used to ensure that Adobe data is accessed only by authorized personnel, with such authorization being based on verifiable business requirements and approvals by the management directly responsible for the confidentiality, integrity, and availability of those resources.

2. Scope

This Standard applies to all access requestors, access approvers and account administrators operating in any environment that collects, stores, processes, transmits, or disposes Adobe data as described in the Data Classification and Handling Standard.

3. Statement

3.1. Requestor

3.1.1 New user requests to access Adobe's corporate data must be placed only after individual is onboarded through the human resources process.

3.1.2 Requestor must open request ticket containing all the required information regarding the access account, including the user, system to be accessed, appropriate permissions, and business justification for the request.

3.1.3 Test and generic accounts must only be used where necessary and removed when not in use. When changes are being made to the production environment, test and generic accounts must be removed before the change.

3.1.4 Creation of anonymous accounts is not permitted. In other words, non-personal accounts that do not have a defined owner.

3.1.5 Request for application and system accounts

3.1.5.1 Application and system accounts and related access privileges are assigned and managed as follows:

- Based on least privileged necessary for the operability of the system or application
- Access is limited to the systems, application, or processes that specifically require their use.

3.1.6 Upon notification of approval and account provisioning, the Requestor – if requesting on behalf of another person – notifies the user that the account is ready for use.

3.2. Approver

3.2.1 Approvals/Rejections

3.2.1.1 A request must be approved or rejected by authorized personnel (see definition below).

Contents

1. Overview
2. Scope
3. Statement
   3.1. Requestor
   3.2. Approver
   3.3. Account Administrator
   3.4. Audit Trail and Procedures
   3.5. All (Requestors, Approvers & Administrators)
4. Definitions
5. Responsibilities
6. Governing Policy
7. References
8. Document Properties
9. Document History

3.2.1.2 Reviews the request ticket to ensure that all requisite information is included, that there is sufficient business justification, and then approves or rejects the request as appropriate.

3.2.1.3 If it is approved, the Approver puts the request ticket into the ticketing queue where it will be assigned or retrieved by the Account Administrator for account creation and provisioning.

3.2.1.4 If the request ticket is rejected for any reason, it is the Approver's responsibility to send the rejected ticket back to the Requester, stating the reasons why the request was rejected.

3.2.1.5 The request for access and access approval must be logged either electronically (preferred) or in writing in a system of record.

3.2.2 Periodic Review of User Permissions

3.2.2.1 Owners (typically managers of information technology resources) must perform quarterly access reviews to ensure accounts:

- Still require access
- Have the appropriate access provisioned for their job function
- Perform evidence retention.

3.2.2.2 Evidence must be retained for a minimum of seven years. After seven years, unless needed for legal or business purposes, the evidence of the access review must be deleted or destroyed.

3.2.2.3 All access by application and system accounts and related access privileges are reviewed as follows:

- Quarterly
- Access remains appropriate for the function being performed
- Any inappropriate access is addressed
- Management acknowledges that access remains appropriate.

3.3. Account Administrator

3.3.1 Account Creation and Provisioning

3.3.1.1 Prior to being given access to Adobe's systems and data individuals must be onboarded through the human resources process and provided a digital identity.

3.3.1.2 Only one active personal ADOBENET ID may be assigned to a worker.

3.3.1.3 Non-personal login IDs must be unique and assigned to an active employee.

3.3.1.4 Approved requests must be communicated to the Account Administrator. The Account Administrator must create a unique user ID for the account associated exclusively with the user named on the approved request, then provision the account in strict accordance with the permissions listed on the approved request.

3.3.1.5 New account IDs must not contain personal information (PI) – see definition below.

3.3.1.6 Once the account has been created and provisioned, the Account Administrator notifies the requester that the account is ready for use.

3.3.2 Role-Based Access

3.3.2.1 Appropriate access (for example, read and write) must only be granted to those who have a need-to-know basis, such as access to Internal, Confidential and Restricted data.

3.3.3 Change in Access

3.3.3.1 Access that is no longer appropriate for various reasons, such as transfers and moves wherein the employee no longer has need for access to the systems in question, must be removed or permissions changed by the Account Administrator. For example:

- Employees transferring from one area of Adobe to another where access to a system in question is no longer required.
- Employees physically moving to a location where access to a specific account is either unnecessary or impractical.

3.3.3.2 Workers converting from one worker type to another, such as from contingent worker to full-time employment with Adobe, or other change in worker type, must have their access and permissions approved by the manager responsible for the systems or environment being accessed.

3.3.4 Account Deactivation and Deprovisioning

3.3.4.1 In the event of an Adobe worker or vendor termination (leaving Adobe voluntarily, reduction in force or dismissal for cause) and a timely termination date set within HRIS, Account Administrators must remove logical access to information systems. Access removal for terminated individuals must accomplish the following:

- Upon termination, the centralized authentication system (for example, OKTA) must have the ability to remove access immediately through a manual process. For example, if an employee is terminated due to the results of an internal investigation, the access must be able to be removed immediately.
- The centralized authentication system must automatically remove access for newly terminated employees within 1 business day of the employee's last day.

- Systems whose access is independent of the centralized authentication system must remove access for terminated individuals within three days.
- For access termination in FedRAMP environment please refer FedRAMP Environment Protection Standard

3.3.5 Adobe Managers (or People Resources) are solely responsible for initiating the termination of employees within the Human Resources Information System (HRIS). The termination date must be set in the HRIS in advance of the termination date.

3.3.6 Contingent worker accounts without activity for 90 consecutive days will be targeted for disablement. In addition, contingent worker accounts without activity in confidential or restricted applications for 90 consecutive days will also be targeted for disablement in the application, regardless of general account activity.

3.3.7 Disabled accounts that are part of the centralized authentication system must be deleted after 90 days.

3.4. Audit Trail and Procedures

3.4.1 An audit trail must be established to show that access requests were approved and documented.

3.4.2 Procedures detailing the access request, approvals, provisioning, deprovisioning, and, where applicable, access reviews, must be created for each individual system and made available to the Requestor, Approver, or Account Administrator performing the required tasks.

3.5. All (Requestors, Approvers & Administrators)

3.5.1 Segregation of Duties

3.5.1.1 Account permissions must be based on the principle of least privilege. Logical access to Adobe information technology resources is restricted solely to authorized personnel with a valid business need for accessing the requested information technology resources. In other words, for the purpose of preventing fraud or error, Segregation of Duties (SoD) must be followed to ensure that the separate, clearly defined roles do not perform tasks that could compromise the confidentiality, integrity, or availability of applicable information technology resources.

3.5.1.2 The following segregation of duties rules apply to Requestors, Approvers, and Account Administrators:

- Requestors cannot approve their own access request. Requestor and Approver must be different people.
- Requestors can neither create nor provision the account associated with the approved access request. Requestor and Account Administrator must be different people.
- Approvers can neither create nor provision the requested account. Approver and Account Administrator must be different people.

4. Definitions

Term	Definitions
Account Creation	Upon receipt of the approved access request ticket, the Account Administrator creates the account. (See Provisioning.)
Archived	These are disabled accounts that contain the same attributes as standard worker types, but which are held in a temporary location for 30 days and then archived. These accounts are defined by the standard worker types but are not active.
Authorized Personnel	Individuals who have met all criteria for accessing specific technology resources and whose credentials have been approved for access and the relevant account created and provisioned. (See also Eligible Personnel.)
HRIS	Human Resources Information System. For example, Workday.
Non-Personal Account	An account that isn't tied to a particular individual but has a defined owner responsible for the account. For example, in Active Directory type 0 accounts would be considered non-personal accounts. These are service accounts, generic accounts (for example, shared accounts), MFA exempt accounts, or privileged accounts.
Personal Account	An account that is tied to a particular individual. For example, a regular employee. These are personnel or provider accounts that are regular employee productivity accounts. These are not service accounts, generic accounts (for example, shared accounts), MFA exempt accounts, or privileged accounts.
PI (Personal Information)	Information that can be used to directly or indirectly identify, contact, or precisely locate an individual.

Term	Definitions
Provisioning	The task of assigning specific access permissions (read-only, read/write, administrative) for the account, in strict accordance with the approved permissions on the access request ticket. Deprovisioning is the process of removing such permissions from the account.
Segregation of Duties (SOD)	In its simplest form, segregation of duties refers to the principle of having clearly defined roles in which two or more individuals are required to perform separate tasks to eliminate the possibility of abuse or fraud. With respect to logical access controls, the principle of SoD is applied so that someone requesting access cannot also be the individual empowered to authorize or provision that access.

5. Responsibilities

Group	Responsibilities
Account Administrator	For responsibilities regarding Account Administrators, refer to Sections 3.3 and 3.5.
Approver	For responsibilities regarding Approvers, refer to Sections 3.2 and 3.5.
Requestor	For responsibilities regarding Requestors, refer to Sections 3.1 and 3.5.

6. Governing Policy

Adherence to the governing Policy referenced below is required to be compliant with this Standard:

- Information Security Policy

7. References

All IT & Security Policies and Standards referenced below can be found here:

- Remote Access Standard
- Authentication Standard
- Data Classification and Handling Standard
- Secure Device Standard

8. Document Properties

Coordinator	Policy Module Admin; Ensures that Approval Occurs	Anastasia Conti (Manager, Governance, TechGRC)
Driver	Coordinates Document Drafting, Reviews and Updates	Todd Powers (Sr. Mgr, Enterprise Security)
Approver	Approves Document and Exceptions; Ultimately Responsible for Execution	Eric Anderson (Director, Enterprise Security)

9. Document History

Version	Approval Date	Changes	Approved By
9.0	December 2024	Major Changes • Section 3 – Restructured entire section to clearly define responsibilities amongst different adobe workers Minor Changes • Section 2 – Restructured section to be more concise • Removed duplicate sections from the governing policy related to 'Exceptions' and 'Violations'	Eric Anderson, Director, Enterprise Security
10.0	October 2025	Major Changes • Section 3.3.2.1 – Added "Internal data" • Section 3.3.6 – Added "contingent worker accounts without activity in confidential or restricted applications for 90 consecutive days will also be targeted for disablement in the application, regardless of general account activity" No Minor Changes	Eric Anderson, Director, Enterprise Security